

Security+ 2.3 · Misconfiguration

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3** —
Misconfiguration (7:09) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Misconfiguration is the most common vulnerability across all systems: default credentials, unnecessary open ports, overly permissive bucket permissions, debug mode enabled in production, weak TLS, and permissive IAM policies. Defense: establish a secure baseline (CIS benchmarks), automate configuration monitoring with CSPM, and review configurations before deployment.

High-Yield Core Concepts Tested on Exam

- Default passwords, open ports, and overly permissive permissions are the #1 cause of breaches
- Defense: secure baseline + automation (CIS benchmarks, CSPM)
- Misconfiguration often results from human error during setup or deployment
- CSPM tools continuously monitor cloud configurations for drift and compliance
- Debug mode in production can leak sensitive information and should be disabled
- Weak TLS configurations and permissive IAM roles are common misconfigurations

Exam Tips & Classic Scenarios

- 'most common vulnerability is human configuration error' = misconfiguration
- 'database exposed to the internet with default credentials' = misconfiguration
- 'unnecessary open port' or 'debug mode enabled' = misconfiguration

Typical Exam Scenario: A company discovers that an Amazon S3 bucket containing customer data is publicly accessible due to overly permissive permissions. Additionally, a database server is exposed to the internet with default credentials. These are examples of misconfiguration.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Misconfiguration)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **CSPM:** Cloud Security Posture Management: Continuous automated compliance and misconfiguration auditing platform for cloud infrastructure (IaaS/PaaS).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In the SHARED RESPONSIBILITY model, who handles the PHYSICAL security of the datacenter?

- A) The customer
- B) The cloud provider
- C) Both equally
- D) An external auditor

2. Difference between IDS and IPS:

- A) IDS detects and alerts; IPS detects and BLOCKS
- B) They are the same thing
- C) IDS is disk-based; IPS is network-based
- D) IPS only logs

3. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Default password / open port / generous permission = the #1 failures.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Default password / open port / generous permission = the #1 failures...
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Defense: baseline + automation (CIS benchmarks, CSPM).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Defense: baseline + automation (CIS benchmarks, CSPM)...

5. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'most common vulnerability is human configuration error' = misconfiguration. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'most common vulnerability is human configuration error' = misconfiguration...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: 'database exposed to the internet with default credentials' = misconfiguration.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Scenario: 'database exposed to the internet with default credentials' = misconfiguration...

7. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.3) exam, an analyst evaluates the following technical requirement: 'Default password / open port / generous permission = the #1 failures'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Default password / open port / generous permission = the #1 failures.

8. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Defense: baseline + automation (CIS benchmarks, CSPM).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Defense: baseline + automation (CIS benchmarks, CSPM)...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'most common vulnerability is human configuration error' = misconfiguration. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'most common vulnerability is human configuration error' = misconfiguration...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Misconfiguration): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: "database exposed on the internet with default credential" = misconfiguration.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Scenario: 'database exposed on the internet with default credential' = misconfiguration...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — The cloud provider.

✓ **Why it is correct:** In the cloud computing shared responsibility model, the physical security of the datacenter — including facility access control, video surveillance, redundant power, climate control, fire prevention and suppression, and protection against natural disasters — is the exclusive responsibility of the cloud provider. CompTIA Security+ SY0-701 emphasizes that the provider is always responsible for 'security OF the cloud' (the underlying infrastructure), while the customer is responsible for 'security IN the cloud' (their data, configurations, identities, and applications). The customer has no physical access to the datacenter and therefore cannot implement physical controls; the responsibility is non-transferable and not shared in this specific aspect.

✗ **Why the others are wrong:**

- *The customer:* The customer is responsible for security IN the cloud, i.e., their data, access configurations, encryption of their information, identity management, and patching of their instances. However, they do not have physical access to the provider's datacenter and cannot install locks, cameras, or fire suppression systems. Assigning physical security to the customer would violate the shared responsibility model, as they do not control the physical environment. The question specifically asks about the PHYSICAL security of the datacenter, which is the provider's exclusive domain.
- *Both equally:* Shared responsibility is not divided equally in all aspects. It is segmented by layers: the provider handles physical security, virtualization infrastructure, and the underlying network; the customer handles the security of their data, applications, and identities. The physical security of the datacenter is a layer the customer cannot operate or directly audit, so there is no equal sharing. Saying both are equally responsible for physical security is technically incorrect and contradicts the model defined by CompTIA and major cloud providers (AWS, Azure, GCP).
- *An external auditor:* An external auditor performs independent compliance assessments, such as SOC 2, ISO 27001, or PCI DSS certifications, but does not execute the physical security of the datacenter. They verify whether the controls implemented by the provider are adequate, but they are not responsible for operating them. Auditing is a verification function, not an operational one. Therefore, assigning physical security to an external auditor confuses the oversight role with the execution role, which is a serious conceptual error in the context of the shared responsibility model.

2) A — IDS detects and alerts; IPS detects and BLOCKS.

✓ **Why it's correct:** The fundamental difference between IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) lies in the action taken after detecting an intrusion. IDS monitors network traffic or system activities for malicious patterns and, upon detection, generates alerts for administrators to investigate. It is passive and does not interfere with data flow. IPS, on the other hand, is active: besides detecting, it blocks or prevents malicious activity in real time, dropping packets, resetting connections, or applying other countermeasures. This distinction is tested in the Security+ (SY0-701) Security Architecture and Design domain, objective 3.2, which covers network security technologies.

✗ **Why the others are wrong:**

- *They are the same thing:* IDS and IPS are distinct technologies with different functions and network placements. IDS is a passive detection system, typically connected to a SPAN port or TAP, analyzing copies of traffic. IPS is an active prevention system, installed inline with the data flow, capable of blocking attacks. Claiming they are the same ignores their operational differences, network impact, and incident response, and contradicts established information security

definitions.

- *IDS is disk-based; IPS is network-based*: This statement is incorrect because both can operate on network or host. There are HIDS (Host-based IDS) and HIPS (Host-based IPS), which monitor activities on a single device, including system calls and file integrity. Similarly, NIDS (Network-based IDS) and NIPS (Network-based IPS) analyze network traffic. The distinction is not between disk and network, but between passive detection and active prevention. The alternative confuses monitoring scope with response mechanism.
- *IPS only logs*: This description applies more to an IDS, which typically logs events and emits alerts. IPS is not limited to logging; its primary function is to actively block intrusion attempts. Although many IPS also generate logs for auditing, its defining characteristic is the ability to prevent attacks in real time, taking actions such as dropping malicious packets or terminating sessions. Reducing IPS to a mere log recorder underestimates its critical active protection function.

3) C — Implement the corresponding solution: Default password / open port / generous permission = the #1 failures....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): Default password / open port / generous permission = the #1 failures. Misconfigurations such as default credentials, unnecessary open ports, and overly permissive access are among the most common root causes of breaches. The correct action is to remediate these misconfigurations by implementing the corresponding secure configuration.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) D — Implement the corresponding solution: Defense: baseline + automation (CIS benchmarks, CSPM)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): Defense: baseline + automation (CIS benchmarks, CSPM).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) A — Implement the corresponding solution: 'most common vulnerability is human configuration error' = misconfiguration....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 2.3 (Misconfiguration): 'most common vulnerability is human configuration error' = misconfiguration. Misconfiguration refers to security settings that are incorrectly set, often due to human error, leading to vulnerabilities.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Scenario: 'database exposed to the internet with default credentials' = misconfiguration....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): Scenario: 'database exposed to the internet with default credentials' = misconfiguration. This correctly identifies a misconfiguration as a security weakness caused by improper system setup, such as leaving default credentials unchanged and exposing a database to the internet, which can lead to unauthorized access.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Default password / open port / generous permission = the #1 failures..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): Default password / open port / generous permission = the #1 failures. These misconfigurations are among the most common vulnerabilities and should be addressed through hardening, changing default credentials, closing unnecessary ports, and applying least privilege.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Defense: baseline + automation (CIS benchmarks, CSPM)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): Defense against misconfigurations involves establishing secure baselines and automating compliance checks using tools like CIS benchmarks and Cloud Security Posture Management (CSPM).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'most common vulnerability is human configuration error' = misconfiguration....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): 'most common vulnerability is human configuration error' = misconfiguration.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: Scenario: 'database exposed on the internet with default credential' = misconfiguration....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Misconfiguration): Scenario: 'database exposed on the internet with default credential' = misconfiguration. This is a classic misconfiguration where a database is accessible from the internet and uses default credentials, making it vulnerable to unauthorized access.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or runtime malware.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.